

THE FORENSICS WAY

ISSUE 29

FORENSICS AWARENESS THIS WEEK

TUESDAY, AUGUST 18, 2026

FRONT PAGE

RANSOMWARE

The Reboot That Killed the Ransom: An Akira Affiliate Rebooted Into Safe Mode to Blind EDR — and Broke Its Own Encryptor

Huntress documented an Akira intrusion that began August 4 with a credential-spray attack against an internet-facing SonicWall SSL VPN account lacking MFA — compromised in under seven minutes. Once inside, the affiliate reached for a first-for-Akira evasion trick: rebooting the victim host into Safe Mode with Networking, a startup state that loads only core drivers and routinely blinds EDR agents that depend on normal-mode services. It is a well-worn tactic against defenders — this time it turned on the attacker instead.

Akira's encryptor is built for speed, leaning on concurrent worker threads and heavy memory-mapped I/O rather than simple sequential reads and writes. Safe Mode's minimal driver set restricted storage controllers and pagefile availability enough to break that architecture outright, and the encryption run failed. Forensic priority: alert on bursts of failed VPN logins against multiple usernames from a single source, monitor msconfig.exe and bcdedit activity alongside boot-configuration event log entries, and treat an unexplained Safe Mode reboot as a live indicator of an EDR-evasion attempt in progress, not routine maintenance.

INSIDER THREAT

Hired, Vetted, and Inside the Perimeter: The FBI Is Investigating How a North Korean IT Worker Landed a Job at a U.S. Federal Agency

FBI Cyber Capabilities Branch deputy assistant director Todd Hemmen disclosed at a July 28 Washington conference that the Bureau is investigating a North Korean remote IT worker discovered in July 2026 working inside an unnamed federal agency — the highest-profile confirmed case yet of a fraud scheme long documented against private employers. Operatives

Threat Bulletin

ACTIVE EXPLOIT

CVE-2026-59310

VMware vCenter — an unauthenticated directory-traversal flaw in the Syslog server lets a remote attacker with network access execute arbitrary code; CVSS 9.8. A suspected APT began exploiting it just five days after disclosure, hitting 360-plus victim IPs across 47 countries and deploying reverse_ssh via cron for persistence; CISA KEV. *Forensic Note:* Inventory internet- and internal-network-reachable vCenter instances, hunt cron-job persistence and reverse_ssh connections, and patch to 9.1.0.0300, 9.0.2.0100, or the relevant 8.0 branch — no workaround exists.

ACTIVE EXPLOIT

CVE-2026-55040

Microsoft SharePoint — a weak-authentication flaw in JWT validation accepts tokens signed with *alg: none*, letting a remote attacker who knows a target's Windows SID forge an admin session with no password; CVSS 9.1. Patched in July, but attackers began exploiting it within hours of a public PoC on August 11; CISA KEV. *Forensic Note:* Review IIS and ULS logs for forged JWT admin sessions, hunt for unauthorized site-collection administrator changes, and confirm the July patch is applied everywhere.

MALWARE SPOTLIGHT

reverse_ssh — The Open-Source Backdoor Riding vCenter's Coattails

use stolen identities, forged documents, and AI-generated deepfakes to clear remote-hiring screens, then funnel their salaries back to programs the State Department says help fund North Korea's weapons development.

The Identity Theft Resource Center logged 21 malicious-insider events in the first half of 2026 alone — seven times the three recorded in all of 2025 — and names the North Korean IT-worker pipeline the single largest driver of that surge. It remains unclear whether sensitive data was accessed. Forensic priority: audit remote-hire onboarding for device-fingerprint and geolocation inconsistencies, correlate VPN and badge-access patterns against claimed work location, and treat identity-verification artifacts — not just credentials — as evidence requiring preservation once insider fraud is suspected.

The vCenter campaign's persistence mechanism is not custom malware at all but reverse_ssh, a legitimate open-source Go tool for establishing outbound SSH tunnels, dropped by a malicious cron job after initial path-traversal access. Because it is a signed, unmodified open-source binary, it evades signature-based detection that would flag a purpose-built implant, while giving the operator a durable, low-noise shell back into the environment. *Forensic Note:* Hunt unexpected reverse_ssh binaries and outbound SSH sessions from server infrastructure, audit cron and systemd timers for unauthorized entries, and treat any unsanctioned use of legitimate remote-access tooling as a compromise indicator, not a false positive.

THE FORENSICS WAY

HISTORICAL ARCHIVES

HISTORY OF DIGITAL INVESTIGATION

TUESDAY, AUGUST 18, 2026

CASE STUDIES: HISTORICAL GRID

THE SNOWDEN DISCLOSURES (2013)

The Insider Who Needed No Exploit: How One Contractor's Access Redefined What "Breach" Means Inside a Trusted Perimeter

In 2013, NSA contractor Edward Snowden used credentials he was legitimately granted to copy and exfiltrate an estimated 1.5 million classified documents, exposing global surveillance programs without triggering a single traditional intrusion alert — there was no malware to reverse-engineer and no exploit to patch, only authorized access misused at scale. The

STUXNET (2010)

Built for One Machine, Broken Everywhere Else: The Worm So Precisely Engineered for Its Target That It Behaved Unpredictably Off It

Discovered in 2010, Stuxnet was purpose-built to sabotage centrifuges at Iran's Natanz facility, checking for exact Siemens PLC configurations before ever activating its payload — a level of environmental specificity previously unseen in malware. That same precision became its exposure: propagation logic meant for a single

subsequent investigation forced intelligence agencies to build insider-threat programs around behavioral analytics and access auditing rather than perimeter defense alone, since the "attacker" had a badge and a login the whole time. That same premise — a fully vetted insider operating from inside the perimeter — is exactly what investigators are now untangling in this week's North Korean IT-worker case.

air-gapped facility carried it onto unrelated networks worldwide, where security researchers caught it precisely because it behaved strangely outside its intended environment. It is the direct ancestor of this week's Akira failure — malware engineered for one operating context, and undone the moment reality didn't match the assumption.

THE EVENT-STREAM INCIDENT (2018)

A Handshake, Not a Hack: How Asking Nicely for Publish Rights Poisoned a Package Downloaded Millions of Times a Week

In November 2018, a developer using the alias "right9ctrl" simply asked the maintainer of the popular npm package event-stream to take over maintenance — no exploit required — then quietly added a dependency, flatmap-stream, carrying an encrypted payload aimed narrowly at the Copay Bitcoin wallet app. A routine code review by another developer, Jayden Seric, caught the anomaly before it detonated at wider scale, and the incident became a landmark case for social-engineered maintainer takeovers. It remains the clearest historical ancestor of last month's CHAINDROP npm worm — the same trust relationship, automated into self-propagation across hundreds of packages instead of one.

GOOTLOADER (2020–PRESENT)

Poisoning the Search Result Instead of the Inbox: The Malware That Weaponized Google Before It Weaponized a Document

Since 2020, the Gootloader operation has ranked fake legal-document and business-template pages at the top of search results through aggressive SEO poisoning, luring professionals searching for contracts into downloading a JavaScript-based loader disguised as the file they wanted. Investigators traced the campaign's staying power to its manipulation of the search layer itself rather than any single payload, forcing defenders to treat "what a search engine surfaces" as an attack surface in its own right — the same technique now aimed at AI agents instead of humans in recent fake-API-documentation campaigns.

TOOLS OF THE TRADE

OPEN SOURCE

Senrigan

YAMATO SECURITY — V1.X

Hayabusa's cloud-facing sibling, built for fast offline threat hunting across AWS CloudTrail logs. Pair it with vCenter and cloud-hosted infrastructure investigations to surface reconnaissance and lateral-movement patterns the moment a

OPEN SOURCE

Zirecolite

WAGGA40 — V2.X

A standalone Sigma-rule engine that runs directly against EVTX without a SIEM. Ideal for hunting the boot-configuration and Safe Mode indicators behind Akira's failed EDR-evasion attempt — bcdedit invocations, unexpected reboots, and service-stop events all

COMMERCIAL

EnCase Endpoint Investigator

OPENTEXT — V25.X

A remote, covert endpoint-investigation platform built for exactly this week's insider-threat scenario: preserving forensically sound evidence from a suspect employee's machine — file access history, USB activity, cloud-upload

UTILITY / SCRIPT

LOLDrivers

LOLDRIVERS.IO — COMMUNITY

A continuously updated database of known vulnerable and malicious signed Windows drivers used in BYOVD EDR-killer attacks. Cross-reference any driver loaded around a suspicious reboot or service termination against LOLDrivers

path-traversal foothold like this week's vCenter flaw starts pivoting into cloud accounts.

resolve to Sigma detections offline.

traces — without alerting the subject or disrupting daily operations.

before ruling out a bring-your-own-vulnerable-driver evasion attempt.

PRIORITY CVE ADVISORIES

ARCHIVE ALERT

CVE-2026-9198 (LANGFLOW OSS)

An insecure default lets any network caller mint a SUPERUSER token, then execute arbitrary Python via `/api/v1/validate/code`; CVSS 9.8, unauthenticated. Fixed in 1.10.1; CISA KEV. *Forensic Note:* Review Langflow logs for `auto_login` calls followed by `validate/code` POSTs, and hunt dropped payloads on pre-1.10.1 hosts.

ARCHIVE ALERT

CVE-2026-18556 / CVE-2026-18577 (N-ABLE N-CENTRAL)

An authentication bypass (CVSS 8.2) let attackers gain administrative RMM access and reach managed endpoints via Take Control; the first patch proved incomplete and a second bypass was exploited before the follow-up fix. Both CISA KEV. *Forensic Note:* Audit N-central admin logins and Take Control session logs, and treat every managed endpoint as potentially touched.

RECENT MALWARE WATCH

ARCHIVE: AUGUST 11, 2026

NOVA RANSOMWARE — THE RUST ENCRYPTOR THAT BLINDS DEFENDER FIRST

A 64-bit Rust encryptor that reconfigures Microsoft Defender, kills security services, and deletes Volume Shadow Copies before encrypting with XChaCha20-Poly1305 and RSA-2048. Hunt Defender configuration-change events and mass service termination as an early-warning pair.

ARCHIVE: AUGUST 4, 2026

MEDUSAHVNC — THE BROWSER ON THE DESKTOP YOU CANNOT SEE

Sold as MaaS via website and Telegram, MedusaHVNC spawns a hidden Windows desktop and opens a browser with the victim's real profile, so fraud flows from the victim's own IP. Hunt `charmapp.exe` with network connections and enumerate hidden desktops in memory captures.